Software Development Life Cycle Policy

Effective Date:
July 14, 2026

Category:
Software

Scheduled Review:
July 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This document replaces, in its entirety, the Software Development Life Cycle Policy, dated February 24, 2025.

3. Purpose

This Information Technology Policy (ITP) establishes requirements that govern software and application development throughout the system lifecycle. It is intended to ensure that all new software, irrespective of hosting model or delivery mechanism, is developed and maintained in a manner that preserves security, quality, interoperability, accessibility, and long-term sustainability.

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

All new application development and enhancement projects are required to utilize a well-documented software development life cycle (SDLC) framework. This requirement applies to projects performed by Commonwealth employees, Commonwealth contractors, and Service Organizations.

The requirements set forth in this policy do not apply to routine operational or maintenance activities, such as minor configuration changes, bug fixes, or other low-risk changes that do not materially impact application functionality, security posture, or business processes,

except where otherwise noted. Such activities shall continue to be managed in accordance with applicable change management, operational procedures, and deployment processes. The processes outlined here are part of modern development and DevSecOps standards and shall be leveraged whenever possible in existing projects and workflows.

Note: Some of the phases and requirements outlined in subsequent sections may not be applicable to existing maintenance contracts.

The activities identified within each phase below are intended to establish minimum requirements and baseline expectations. Agencies may implement more stringent requirements so long as they don't conflict with those minimum requirements outlined in this policy. These phases are meant to be iterative. One phase does not need to be fully completed to start another, and several can happen in parallel as more information is gathered.

5.1 Project Initiation

Agencies seeking software solutions shall review the Enterprise Service Catalog to determine if an enterprise standard service offering exists. If an enterprise standard service offering is identified in the Enterprise Service Catalog, agencies shall adhere to the guidance in the *IT Project and Procurement Policy* regarding the use of that service offering.

Agencies shall give first preference to software listed as a current product standard in any of the existing ITPs. Agencies that seek an exemption from current product standards shall work collaboratively with OA/IT to submit an IT policy exception as outlined in *IT Policy Governance*.

Agencies shall request and receive approval for IT projects in accordance with the *IT Project and Procurement Policy*.

Prior to the commencement of design activities, agencies shall complete a formal risk assessment and security impact analysis.

Solution selection shall be based on fitness for purpose and alignment with enterprise standards. Vendor preference shall not be the determining factor in selecting a solution.

To support reduction of the Commonwealth's legacy and customized application portfolio, agencies planning new, modernized, or replacement applications are encouraged to evaluate reuse of existing Commonwealth solutions. Agencies shall also evaluate Commercial-off-the-Shelf (COTS) and Software-as-a-Service (SaaS) offerings where they reasonably meet business and technical needs. Where such options do not provide an appropriate fit, in-house solutions may be developed based on documented project requirements and available internal capabilities.

5.2 Planning

Project teams shall produce and maintain high-level system architecture diagrams that identify system components, integration points, and data flows.

Security requirements, including authorization, authentication, encryption and applicable compliance obligations shall be documented and incorporated into a project plan.

Where applicable, Commonwealth accessibility requirements shall be addressed during the planning phase in accordance with the *Digital Accessibility Policy*.

For projects involving web applications, Application Programming Interfaces (APIs), mobile applications, or other components subject to the requirements of the *Commonwealth Application Certification and Accreditation (CA2) Policy*, agencies shall prepare a plan to submit all required documentation in accordance with established CA2 procedures.

5.3 Design

Major technical decisions shall be documented in Architecture Decision Records (ADRs). Such decisions include, but are not limited to, selecting of development frameworks, architectural patterns (monolith vs. microservices), database platforms, and significant design approaches. ADRs shall be maintained within the project's version control repository in a designated location or folder.

Design artifacts shall demonstrate adherence to established engineering and security principles, including modularity, reusability, least privilege, and secure by design practices.

Application Program Interface (API) specifications shall be documented using an open, industry-recognized standard and maintained in a version-controlled repository accessible to the project team and authorized Commonwealth personnel.

Database schemas and data models shall be documented and retained as part of the official project record.

It is strongly recommended that critical user flows be prototyped and validated with stakeholders or end users prior to full implementation and that user experience design resources are engaged early in the project and throughout the SDLC to ensure user needs are being met.

5.4 Development

Source code shall be maintained in a Commonwealth-approved version control system and must follow industry-standard branching and code review practices (see: branching and version control guidance). Any change, regardless of size, shall undergo peer review by at least one qualified human reviewer prior to merge. Branch protections shall be enforced for production branches.

Secure coding standards, including static and dynamic code scanning shall be applied and enforced through automated tooling whenever possible through Continuous Integration and Continuous Delivery mechanisms (CI/CD). Exceptions shall be documented and approved via the IT policy exception process as outlined in section 7 and include a completed *IT Risk Acknowledgement Form*.

Third-party dependences shall be inventoried and managed to identify known vulnerabilities and licensing obligations and must be updated to major versions regularly.

Credentials shall not be stored in source code and shall be stored in Commonwealth-approved secrets management systems.

Agencies shall maintain a minimum of three (3) distinct environments for all active projects. Refer to the SDLC Environment Guideline for additional information.

Project documentation shall include at least one README file at the root of the project. At a minimum, the README file shall contain:

- Instructions for running the project locally;
- An overview of the business needs met by the project;
- Required dependencies; and
- Testing suite information.

5.5 Testing and Quality Assurance

Automated and manual testing shall be integrated into the development lifecycle and include unit, integration, and regression tests where practicable.

Security testing shall encompass Static Application Security Testing (SAST), and Dynamic Application Security Testing (DAST), using the tools outlined in the *Software Development Lifecycle Standard* and commensurate with the application's risk profile. These scans shall wherever possible, be run automatically within a codebase's CI/CD pipeline, as early as possible throughout the development process. Software Composition Analysis (SCA) reporting shall also be run where appropriate, to ensure open-source tool usage is cataloged.

Security validation shall be performed prior to production release. Manual penetration testing is strongly encouraged, especially for high-impact applications. Any outstanding high or medium-risk findings require documented risk acceptance and an approved remediation plan.

Vulnerabilities identified through testing shall be remediated prior to production deployment. Where remediation is not feasible prior to go-live, agencies shall obtain an approved *Risk Assessment and Acknowledgment Form* and have a documented remediation plan.

Performance and load testing shall be conducted to validate capacity and scaling behavior prior to production release.

Accessibility testing shall be completed where required by the *Digital Accessibility Policy*. Results and remediation plans (if applicable) must be documented prior to release.

Unit tests, smoke tests, and end-to-end testing shall be included whenever possible. System integration testing, and end-to-end interface testing shall be performed when changes impact business needs.

Where possible the testing mentioned above shall be automated and integrated through the Commonwealth's Continuous Integration and Continuous Delivery (CI/CD) pipelines.

5.6 Deployment

Production releases shall be executed through automated, version-controlled CI/CD pipelines that include build automation, test execution, security scanning, code review, and approval gates where supported. CI/CD pipelines are not required for low-code/no-code platforms that do not support them."

Rollback and disaster recovery (DR) procedures shall be documented and tested prior to production launch. Whenever possible, infrastructure changes must be managed through versioned Infrastructure as Code (IaC) to ensure consistency and traceability.

Environment naming and configuration shall conform to enterprise conventions and be fully parameterized to avoid hard-coded values. Wherever possible, configuration changes shall be deployed through the same CI/CD processes as application code.

Separation of duties throughout the development and deployment lifecycle are required. Role-Based Access Control (RBAC) shall be used wherever possible, and the principle of least privilege shall govern all access to code repositories, build systems, environments, and production resources.

5.7 Operations

Applications shall be instrumented for observability, including structured logging, metrics, and tracing where applicable. Logs must be sent to the Commonwealth Enterprise log aggregator solution and must meet retention and compliance requirements as outlined in the *Security Logging and Event Monitoring Policy*. Monitoring must cover availability, performance, error rates, resource utilization, and key business metrics, and alerts must be severity classified and routed to designated on-call personnel. Each system must define and maintain Service Level Indicators (SLIs), Service Level Objectives (SLOs), and Service Level Agreements (SLAs) appropriate to its classification and business impact.

Incident response runbooks and on-call schedules shall be maintained and accessible to operational staff. Backups for critical data and configuration are required, and backup and restore procedures must be tested prior to go live. Failover and disaster recovery procedures shall be validated and Recovery Point Objectives and Recovery Time Objectives documented.

Release Management ensures that every production change is packaged, versioned, approved, and communicated in a predictable, auditable way. Each release shall include a documented set of changes, pass all required testing and security checks, produce an immutable versioned artifact, and include validated rollback and DR procedures. Releases move through defined approval gates enforced by CI/CD pipelines, with clear communication to stakeholders about timing, impacts, and required actions. After deployment, teams shall verify system health, monitor for anomalies, and conduct post-release reviews for significant changes to drive continuous improvement.

5.8 Retirement

Decommissioning systems shall follow the *Records Management Policy* and include secure data disposal and archival of code, documentation, and operational artifacts. Resource cleanup must remove unused accounts, test data, server resources, DNS entries, certificates, and all unused infrastructure to reduce attack surface and ongoing cost.

5.9 Completion Criteria

Each project must demonstrate the following before production launch:

- Documented evidence for design, security review, and testing results.
- Operational runbooks, monitoring dashboards, and on call assignments in place.
- Backup and recovery validation completed.
- Accessibility and compliance checks completed or formally given an exception.
- CA² or equivalent accreditation artifacts prepared where required.
- An entry has been completed in the Enterprise Application Inventory.

5.10 Enterprise Software and Application Development Standards

New application development projects shall use the current standard products, tools, and development languages as defined in the *Software Development Life Cycle Standard.*

6. Contact

Questions or comments may be directed via email to OA, IT Policy

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document
Revision	02/24/2025	Added document control Replaced Cloud Use Case with new Vendor Risk Assessment process. Replaced IT Investment Process with the new IT Procurement Intake Process
Revision	07/14/2026	Policy substantially revised. Reorganized requirements into lifecycle phases Added new requirements related to: • Risk assessment/ impact analysis • Architecture decision records • API and database documentation • Version control • Peer review • Branch protections • Security scanning • Dependency management • Secrets management • CI/CD pipelines • Environment management • Observability • Release management • Disaster recovery • Backups • System retirement activities. Updated testing requirements Moved guidance related to web development and design into a separate standards document.

Version	Date	Purpose of Revision
Revision	10/22/2026	Removed the Software Licensing and Software Contracts sections and relocated the requirements to the *IT Project and Procurement Policy*.